

컴닥터(ComDoctor) 상세 인스펙션 보고서

1. 개요

- 작성대상: 저장소 주요 구성요소

- server/index.js, server/routes/analyze.js, server/logger.js, server/db.js
- electron-app/main.js, electron-app/preload.js, electron-app/renderer/app.js
- comdoctor.py
 - 목적: 문법 오류·환경 의존성·보안·운영 리스크 식별 및 우선순위별 개선 작업 제안

2. 검사 범위 및 방법

- 범위: 코드 정적 읽기, 위험 패턴 검색, 환경 변수 의존성 확인
- 방법: 파일별 수동 코드 검토, 텍스트 검색(`process.env`, TODO/FIXME, 외부 API 호출), 간단한 실행 가능성 확인(로컬에서 `node --check`는 사용자 환경에서 권장)

3. 파일별 주요 발견 및 권고

- `comdoctor.py` (빈 파일)
- `server/index.js`
 - 리스크: app.listen이 127.0.0.1에 묶여 있어 외부 접근 제한됨(의도적일 수 있음). 로그 파일 권한/디스크 용량 고려 필요.
 - 권고 작업: 운영 환경에서 bind 주소 재검토, 로그 파일 회전(rotate) 또는 외부 로그 수집 연동.
- `server/routes/analyze.js`
- `server/logger.js`
- `server/db.js` (스텝)
 - 발견: saveAnalysis 미구현(주석으로 TODO).
 - 영향: 분석 결과 영구 저장 불가, 통계/이력 기능 동작 불가.
- `electron-app/main.js` 및 `preload.js`
 - 리스크: execFile('powershell.exe'...) 사용은 Windows 전용이며 권한/환경에 따라 실패 가능. 출력을 직접 JSON으로 파싱하므로 파싱 실패 위험.
 - 권고 작업: 실패 케이스(권한 거부, 명령 미존재)에 대한 사용자 메시지 개선, 수집 스크립트 결과 검증 강화.
- `electron-app/renderer/app.js`

4. 취약성/리스크 요약

- 환경변수 미설정: `GEMINI\_API\_KEY`, NAVER 관련 키 미설정 시 주요 기능 비활성화.
- 외부 의존성: Gemini API, Naver 쇼핑, PowerShell에 의존적이며 네트워크·플랫폼 이슈 발생 가능.
- 데이터 저장 부재: DB 스텝으로 분석 이력 미저장.

5. 권장 작업 목록(작업별: 설명 · 예상 작업량 · 우선순위)

- A. 환경 변수 문서화 및 검증
 - 설명: .env.example 확장으로 필수 키 목록과 사용 방법 명시, 앱 시작 시 필수 키 체크와 친절한 에러 메시지 추가.
 - 예상 작업량: 1~2시간

- 우선순위: 높음

- B. `server/db.js`에 간단한 SQLite 구현 추가

- 설명: 결과 저장을 위해 sqlite3 또는 better-sqlite3로 간단한 테이블과 saveAnalysis 구현.

- 예상 작업량: 2~4시간 (마이그레이션 스크립트 포함)

- C. 외부 API 래퍼와 목(Mock) 주입 구조

- D. 로그 롤링과 에러 포맷 정리

- 설명: winston 등 로그 라이브러리 도입 또는 파일 롤링 정책 적용.

- 예상 작업량: 1~3시간

- E. 클라이언트(렌더러) XSS/입력 검증 개선

6. 과제 제출용 체크리스트 (권장 형식)

- [] `comdoctor.py`에 샘플/기능 구현 추가 및 `python -m py\_compile` 통과
- [] `node --check` 및 `npx eslint .` 결과 스크린샷 또는 로그 첨부
- [] `.env.example` 업데이트 (필수 키 목록)
- [] `server/db.js` 기본 영속화 구현 추가
- [] 외부 API 목(Mock) 테스트 케이스 1개 이상 추가

7. 부속 자료

- 간단한 수정 예시 스니펫(환경변수 체크, DB save 예시 등)을 원하시면 추가로 제공합니다.

작성자: 자동 인스펙션 도구